

DNS Security Reading Assignment

Name - Atish Kadam

Roll No – CS25MTECH14003

Q1. The BIND 9 Vulnerability (CVE-2025-40778)

Root Cause and the Violation of DNS Trust Assumptions

CVE-2025-40778 is a problematic in BIND 9's resolver validation. This breaks the DNS bailiwick principle. Normally, resolvers can only cache (save) records within the queried domain's authority, but vulnerable versions accept unsolicited records from the Additional section, allows attackers to inject some text like A, AAAA, or CNAME records for unrelated domains. This violates the core DNS trust model, where an authoritative server should not influence records outside its own domain.

By accepting this type of data, BIND 9 allows attackers to exploit the DNS cache, attackers gain a "skeleton key" to manipulate domain resolutions. The main issue is a violation of trust scope. Where resolvers assume servers respond only within their authority, but this flaw breaks that boundary.

This vulnerability bypasses longstanding DNS defenses like source port randomization, transaction ID randomization, and 0x20 encoding. Unlike Kaminsky attack that required guessing parameters, our CVE-2025-40778 lets attackers succeed easily because they control the authoritative server.

This enables attackers to do traffic redirection, credential theft, malware delivery, and infrastructure compromise with high stealth.

Why Cache Poisoning Becomes Dramatically Easier

Before this Kaminsky attack, are based on brute force flooding resolvers with forged responses and racing to match transaction IDs and source ports, generating detectable traffic anomalies.

In contrast, CVE-2025-40778 overcomes this complexity. As the attacker controls the authoritative server, no guessing is needed, and as few as one or two packets can successfully poison the cache.

By setting long TTL values (e.g., 24 hours), a single injection can persistently misdirect traffic for all downstream users until expiration.

Attack steps - the attacker registers a domain -> runs a malicious authoritative server -> lures a resolver into querying it (via a webpage, email, etc.), -> responds with both legitimate and poisoned records. Due to the flaw, the resolver caches everything without validation.

The vulnerability affects BIND versions 9.11.0 through 9.21.12 and targets recursive resolvers (authoritative-only servers are safe unless recursion is enabled). With a CVSS score of 8.6, it is network-exploitable, low complexity, requires no privileges or user interaction, and impacts systems beyond the vulnerable component.

Q2. The Detour Dog Campaign

The Complete Attack Chain

Many websites are mainly compromised WordPress sites are infected with malware that uses DNS for stealthy, server-side redirection, invisible to visitors. The malware sends specially crafted DNS queries containing the visitor's IP, device type, and other data to a command-and-control (C2) server, enabling targeted decisions. Most users see normal content, helping the infection remain undetected for long periods.

In 2025, the attack evolved to include remote code execution. DNS TXT responses (Base64-encoded and marked with "down") trigger infected sites to fetch and execute code from servers controlled by author, sending results back to the victim's browser.

This forms a multi-stage attack chain: phishing emails with malicious SVG attachments (spread via botnets like REM Proxy and Tofsee) deliver the StarFish backdoor from compromised sites. StarFish can then download Strela Stealer, an information-stealing malware targeting mainly European users. DNS acts as the backbone and via different compromised hosts it directs each stage downloader scripts and final payloads.

DNS as an Active C2 and Delivery Mechanism

Detour Dog is uniquely sophisticated because DNS is not just used for resolution and it also serves as the central intelligence and control layer. The attacker-controlled authoritative server interprets specially crafted DNS queries as commands and returns encoded instructions, effectively turning DNS into both a command-and-control and delivery channel.

From June 2025, responses began directing infected sites to fetch outputs from Strela Stealer C2 servers, indicating a full malware distribution system driven by DNS. The attack uses deliberate misdirection: malicious attachments appear to reference benign compromised websites, while the actual payload is fetched from different servers via DNS TXT instructions hiding the true source and misleading analysts.

This **three card monte** design increases anonymity and resilience by performing routing activity through multiple compromised sites. Even when the Shadowserver Foundation sinkholed the main C2 domain, Detour Dog quickly adapted this by deploying a new domain within hours and regaining control of around 30,000 infected hosts within 48 hours demonstrating the robustness of its DNS-driven architecture.

Q3. Comparison of DNS Exploitation Methods

DNS as a Target: Cache Poisoning and Hijacking

When DNS is the target, attackers aim to corrupt the resolution process so users are silently misdirected even though they have entered correct URLs. These attacks are upstream and invisible, This doesn't give any warning to victim.

CVE-2025-40778 is a good example which poisons a single ISP resolver and that impacts millions, redirecting users to convincing phishing sites. Domain hijacking results in a similar outcome from a different angle by taking control of domain registration or DNS records.

Techniques include weak registrar security (no MFA), social engineering, expired domains, DNS record manipulation, and exploitation of resellers. In both cases, attackers control the "phonebook," ensuring all lookups return malicious destinations without user awareness. The D-Link CVE-2026-0625 vulnerability shows DNS targeting at the edge device level.

Due to an authentication bypass in the dnscfg.cgi endpoint, attackers can modify router DNS settings without credentials. While CVE-2025-40778 targets resolver logic, this flaw targets router administration but both result in the same outcome: all user DNS traffic is transparently redirected through attacker-controlled infrastructure.

DNS as Attack Infrastructure: Malware Delivery and C2

When DNS is used as part of attack infrastructure, it is not disrupted but instead weaponized as a communication channel. Attackers control the authoritative DNS server and use it to issue commands, exfiltrate data, and manage different stages of malware. In the Detour Dog campaign, specially crafted DNS queries are treated as commands, while responses often delivered through TXT records contain encoded instructions, URLs, or execution triggers, effectively turning DNS into an active command-and-control system.

DNS is well suited for this role because it is widely used, typically allowed through firewalls, and rarely inspected in depth. This makes such activity difficult to detect. TXT records, in

particular, provide flexibility for transferring data, including staged malware delivery such as downloader scripts followed by payloads.

The key distinction lies in intent:

- DNS as a target: attackers compromise the resolution process to redirect users on a large scale.
- DNS as infrastructure: attackers use DNS as a covert communication channel between attacked systems and their own servers.

In the second case, DNS continues to function normally. Queries and responses remain valid, which makes detection challenging because the malicious activity blends in with legitimate DNS traffic.

Q4. Weak DNS Governance and Domain Hijacking

How Governance Failures Enable Large-Scale Attacks

DNS governance failures occur at multiple levels and it creates different attack entry points. At the registrar level -weak credential hygiene, reused passwords, lack of MFA, and poor account management allows attackers to gain access and modify DNS records. Social engineering further enables attackers to impersonate domain owners and convince registrars to make unauthorized changes.

Campaigns like SubdoMailing and Sitting Ducks show the scale of exploitation. Attackers used thousands of trusted domains and subdomains for fraudulent activities, benefiting from inherited reputation, including SPF and DKIM, which makes phishing, business email compromise, and malware distribution more effective.

Risks increase with expired domains and decentralized management. When organizations let domains expire, attackers can reuse their residual trust. Misconfigurations like dangling CNAME records create "Sitting Ducks," allowing anyone to claim associated services.

The Detour Dog case shows us registrar failure, where WebNIC ignored abuse reports and believe on customer claims despite evidence. Even after ICANN's breach notice, inaction showed how unresponsive registrars enable sustained malicious campaigns.

Why These Attacks Are Harder to Detect

DNS-based attacks exploiting governance failures are highly stealthy because they weaponize legitimacy. A hijacked domain still appears valid to users, browsers, email filters, and monitoring tools, retaining valid registration, SSL certificates, and a trusted reputation. Once compromised, it becomes a powerful tool for deception, enabling brand

impersonation through fake login pages or cloned websites, leading to credential theft and privacy breaches.

Unlike traditional intrusions that trigger alerts (e.g., unusual traffic or privilege escalation), domain hijacking often goes undetected because it occurs outside the victim's network at the registrar or DNS level leaving internal systems untouched. Additionally, hijacked domains can enable supply chain attacks. If linked to vendors or service providers, attackers can exploit trusted relationships to impersonate connections, steal credentials, and move laterally into more secure environments, making such attacks especially difficult to detect.

Q5. Persistent Weaknesses in DNS

Reason 1: The Protocol Was Designed for Trust, Not Security

- DNS was originally built for a trusted or Authorized environment, DNS is prioritized speed over security and didn't include good authentication or integrity checks.
- As a result, most DNS resolvers still can't verify whether a response truly comes from a right server.
- Although later DNSSEC added cryptographic validation, it is not deployed everywhere especially inside enterprise networks. This leaves systems vulnerable to attacks like cache poisoning.
- The vulnerability CVE-2025-40778 exploits this weakness by taking advantage of BIND 9's trust that servers only send valid data within their authority.
- Since this trust isn't cryptographically enforced, attackers can inject malicious records, breaking a core assumption of DNS security.

Reason 2: DNS Traffic Is Ubiquitous, Unrestricted, and Rarely Inspected

- DNS traffic is needed for internet use, so firewalls and security tools usually allow it without proper checking. This makes DNS a perfect hidden channel for attackers.
- In the Detour Dog campaign, attackers used DNS requests made by servers (not visible to users) to communicate and stay hidden.
- And most of the security systems don't check DNS response content (like TXT records), the attack Remains undetected for long periods.
- Similarly, CVE-2026-0625 shows how does attackers can change router DNS settings. Once compromised, they can redirect traffic, rob credentials, or inject malicious content and users will not be aware of that .
- Overall, DNS-based attacks succeed because they operate in a trusted, rarely monitored layer of network communication.

Reason 3: The DNS Ecosystem Has Too Many Weak Links —> Registrars, Devices, and Software

- DNS security is weak because it depends on many layers and each has vulnerabilities:
- **Registrar layer:** Poor governance can lead to domain hijacking.
- **Resolver layer:** Bugs like CVE-2025-40778 expose widely used DNS software.
- **Device layer:** Issues like CVE-2026-0625 affect routers that are no longer supported, meaning they will never be patched.
- Many devices (especially IoT and routers) remain vulnerable for years due to lack of updates and difficult maintenance. At the same time, decentralized domain management leads to forgotten or misconfigured domains, increasing risk.
- Combined with DNS being a trusted and poorly monitored channel, these weaknesses make it one of the easiest and most persistent attack surfaces in cybersecurity.